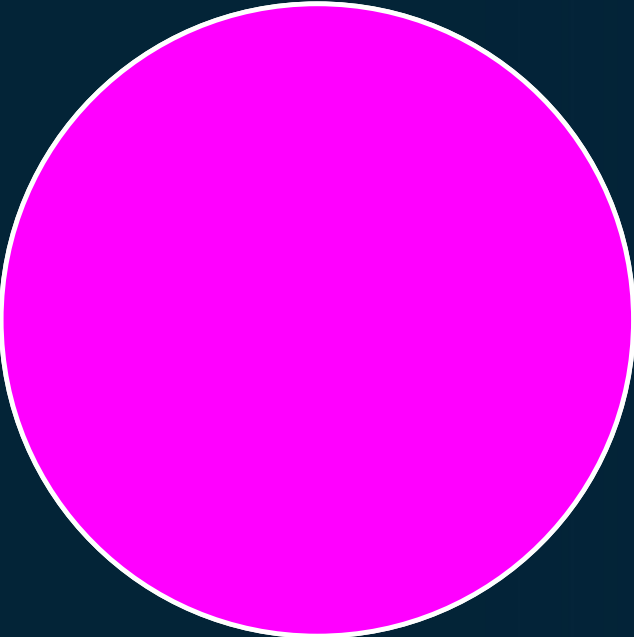


AI Governance Structures

Chapter 11 · Episode 01 · Domain 4.1 — Who Decides How AI Is Used



Learning Objectives

1. Governance structures
2. Roles and responsibilities
3. Responsible AI principles
4. Risk categories
5. Shadow AI
6. Regulatory frameworks: UI, Act, ISO or OECD
7. Corporate policies
8. 3rd-Party AI sovereignty

AI Center of Excellence



STANDARDS

Permitted apps & data rules
Testing bars pre-deploy



ENABLEMENT

Frameworks & reusable parts
Compliance made easier

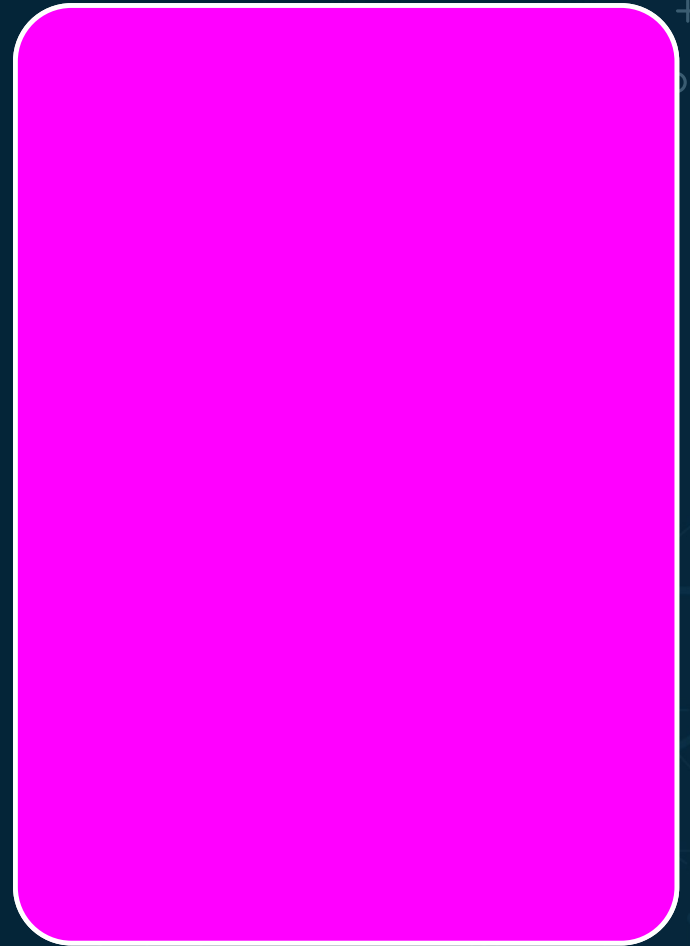


RISK

Initiatives vs risk framework
Gate before deployment

Committee Decides, CoE Advises

- Approve AI use cases
- Set risk tolerance thresholds
- Review AI incidents
- Ensure regulatory alignment
- Documented escalation criteria



AI Governance Policy Framework



ACCEPTABLE USE

Permitted apps,
data, purposes



DATA RULES

Classification & privacy bars



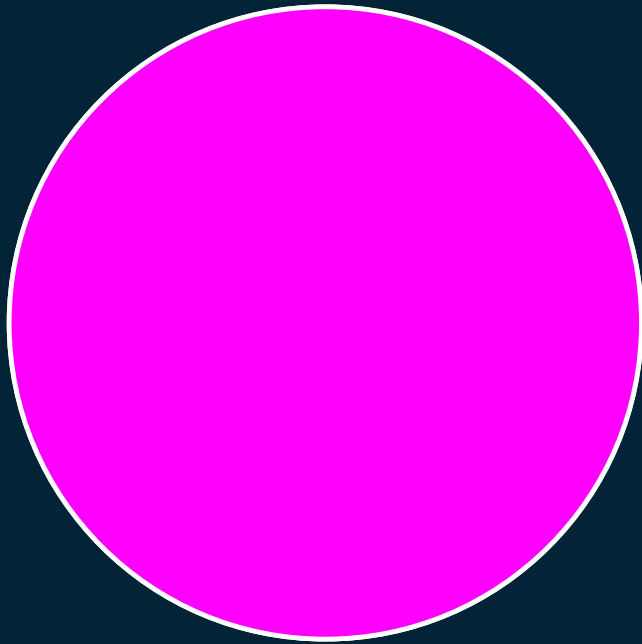
PROHIBITED

Uses the org will not pursue



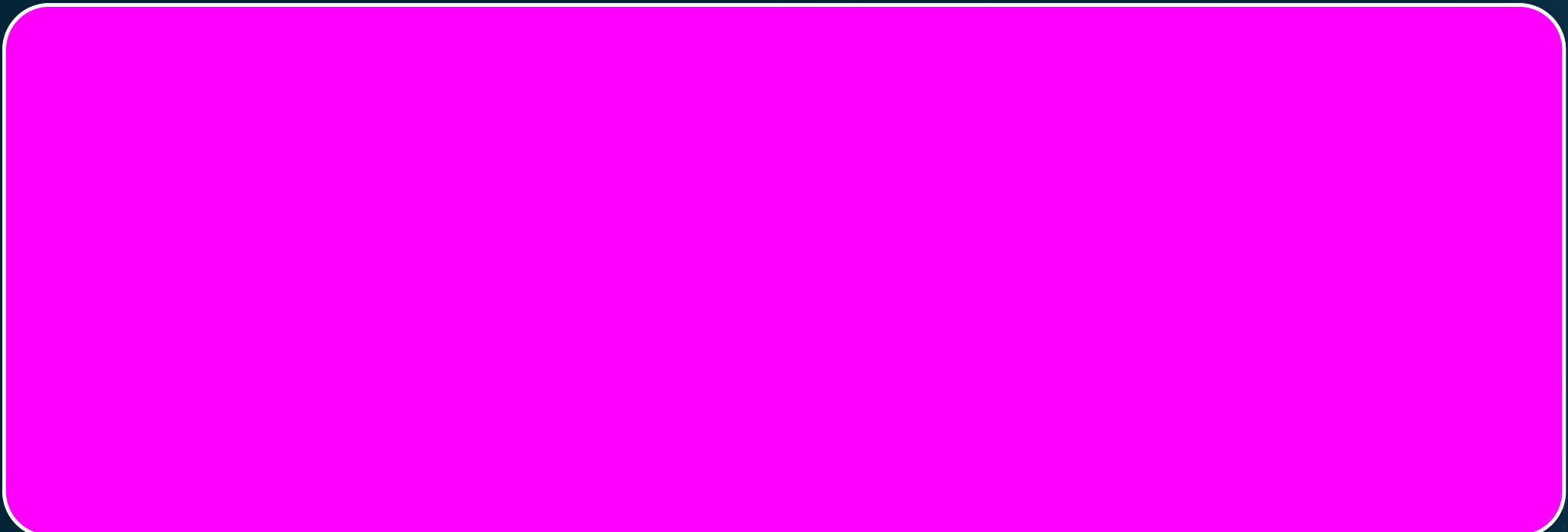
THIRD PARTY

Vet, contract, monitor vendors



Maturity Levels

1. Ad hoc — no structured governance
2. Developing — inconsistent policies
3. Defined — CoE & committee working
4. Managed — metrics & improvement
5. Optimizing — evolves proactively



Demo: Governance Audit

Colab sim — CoE functions, policy completeness, maturity scoring

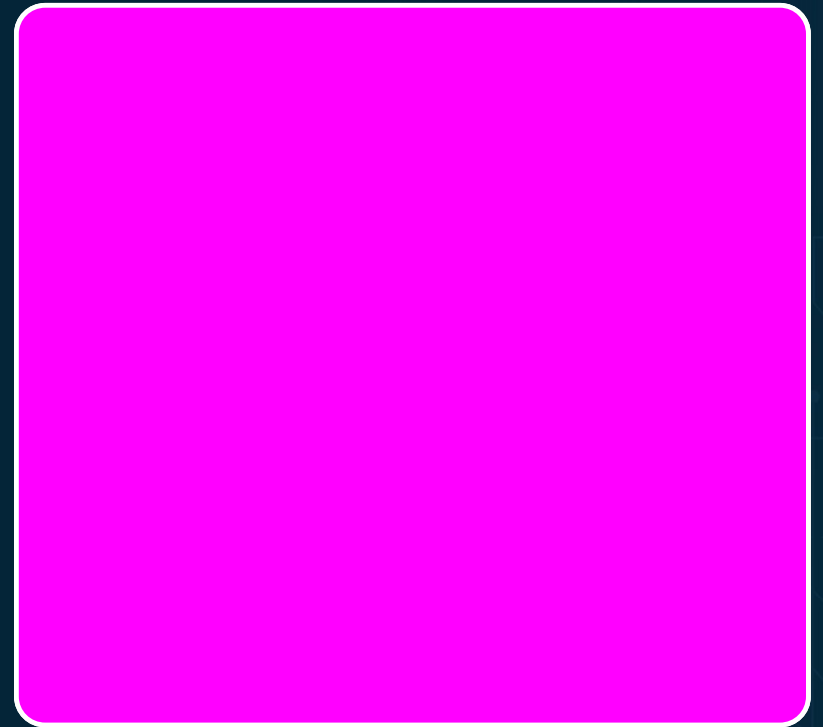
Exam Tips: Governance Structures

CoE advises & implements — committee decides

Escalation thresholds = documented risk

Four policy framework components

Five maturity levels — match the org



AI Roles and Responsibilities

Chapter 11 · Episode 02 · Domain 4.1 — Who Owns What in AI Governance

Business vs Technical Owners

AI PRODUCT OWNER

Defines business objective

Accepts business risk

Owns business outcomes

AI/ML ENGINEER

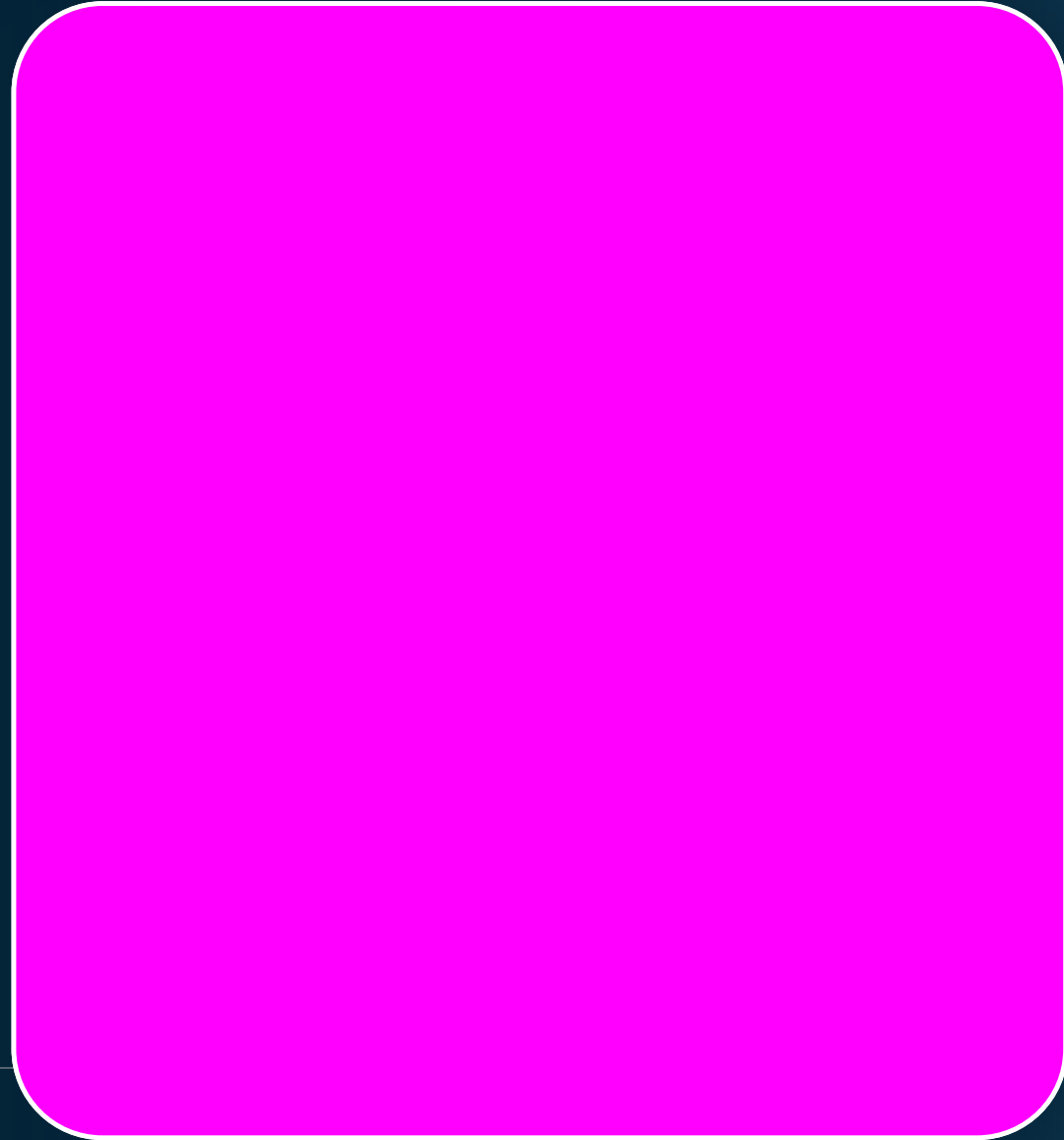
Model selection & training

Evaluation & deployment

Owns technical performance

Security & Ethics Officers

AI Security Officer secures AI
Adversarial monitoring & tests
Ethics / RAI Lead owns fairness
Advises on risky use cases



Supporting Governance Roles

STEWARD

Data quality & classification
Training-set accountability

AUDITOR

Independent verification
Separate from CoE & ops

LEGAL

Regulatory adherence
Reviews vendor contracts

Accountability Structures

RACI

Own, do, advise, inform

ESCALATE

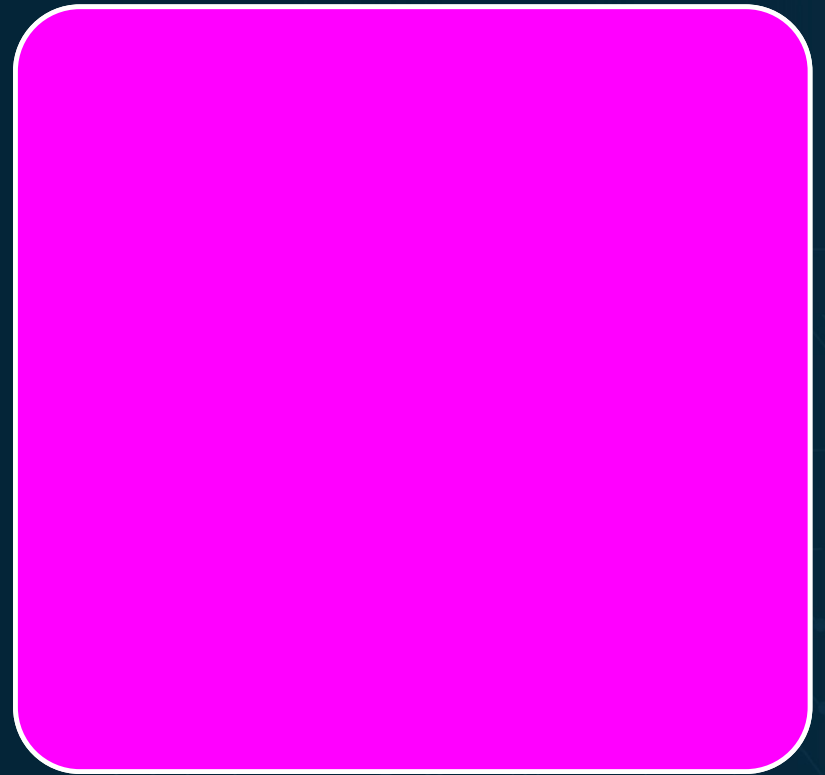
Chain for AI harm events

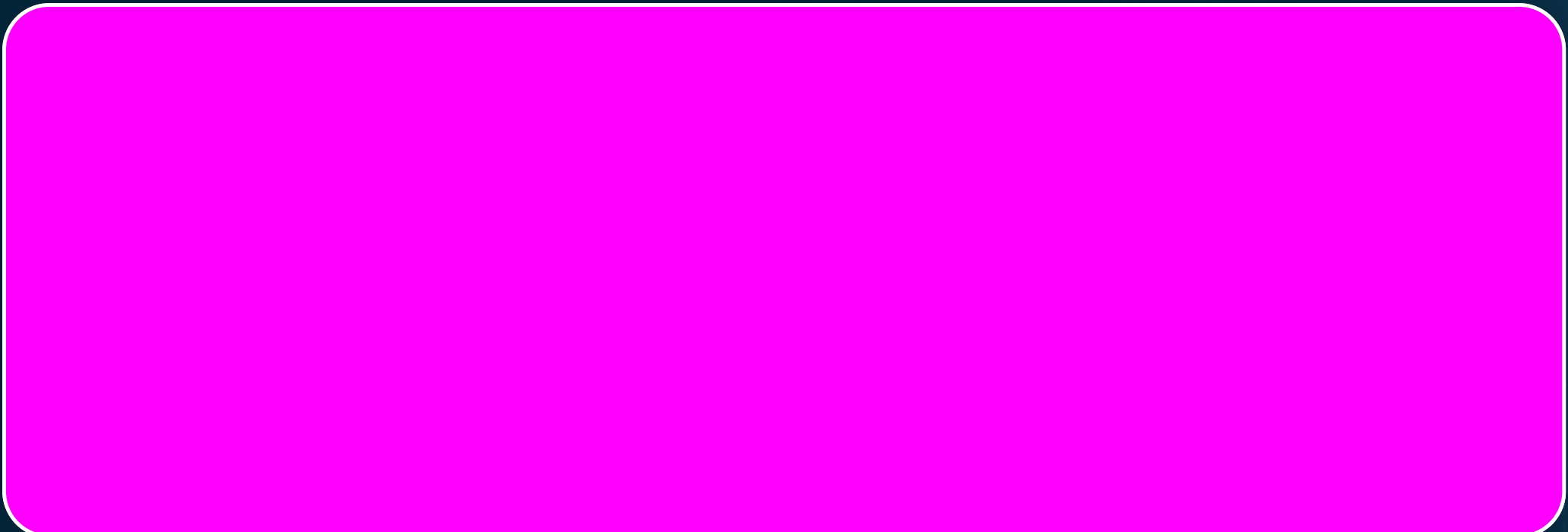
COORDINATE

Six roles span deployment

EXAM CUE

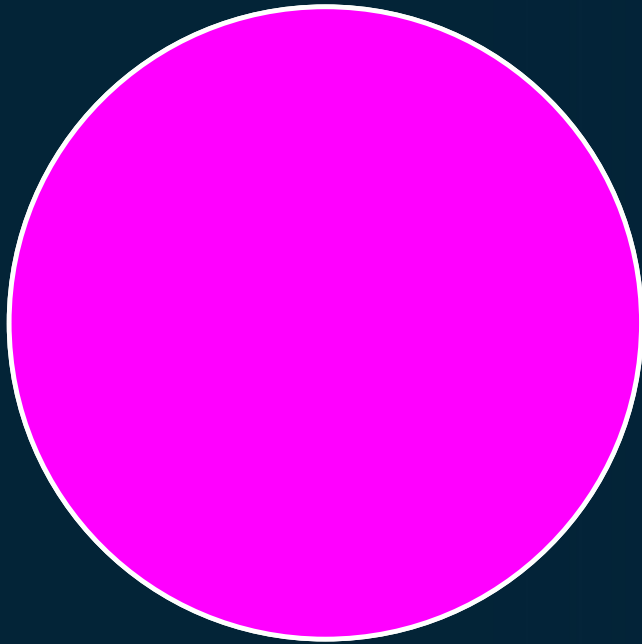
'Nobody owned the problem' = RACI / escalation gap





Demo: Role Registry Audit

Simulation — six roles, RACI matrix, escalation paths, gap detection



Exam Tips

1. Product Owner — business outcomes
2. Engineer — technical performance
3. Security Officer · ethics lead
4. Data Steward · independent auditor
5. RACI + escalation close the gaps

Responsible AI Principles

Chapter 11 · Episode 03 · Domain 4.2 — Five Principles, Operationalized

Fairness: Two Tested Metrics

DEMOGRAPHIC PARITY

Equal positive outcome rates

Across demographic groups

EQUAL OPPORTUNITY

Equal error rates (esp. FN)

Violation = skewed flag rates

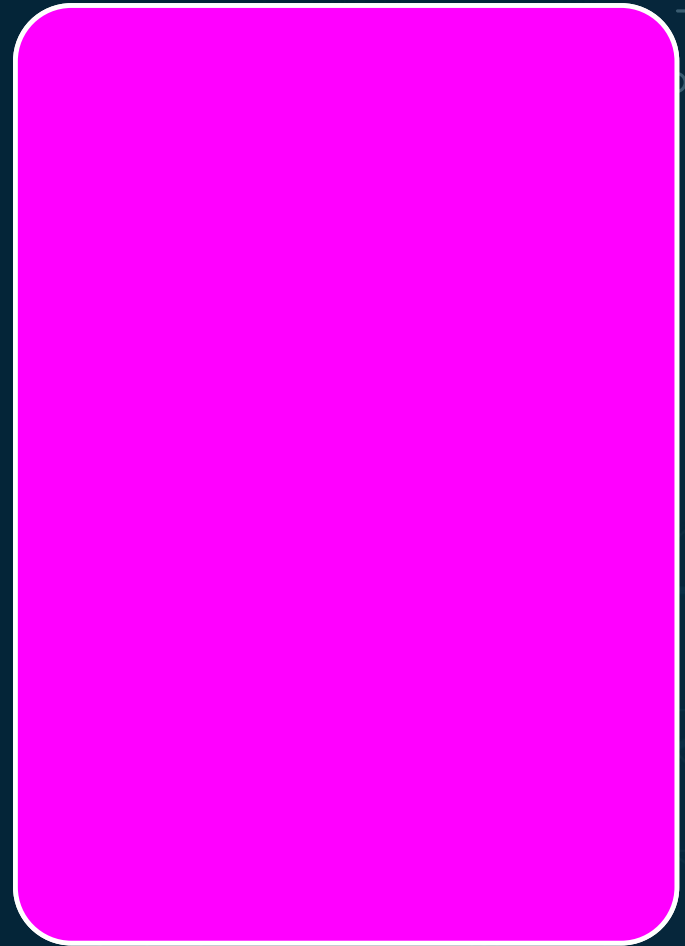
Transparency ≠ Full Disclosure

Stakeholders know AI is involved

Factors behind decisions shared

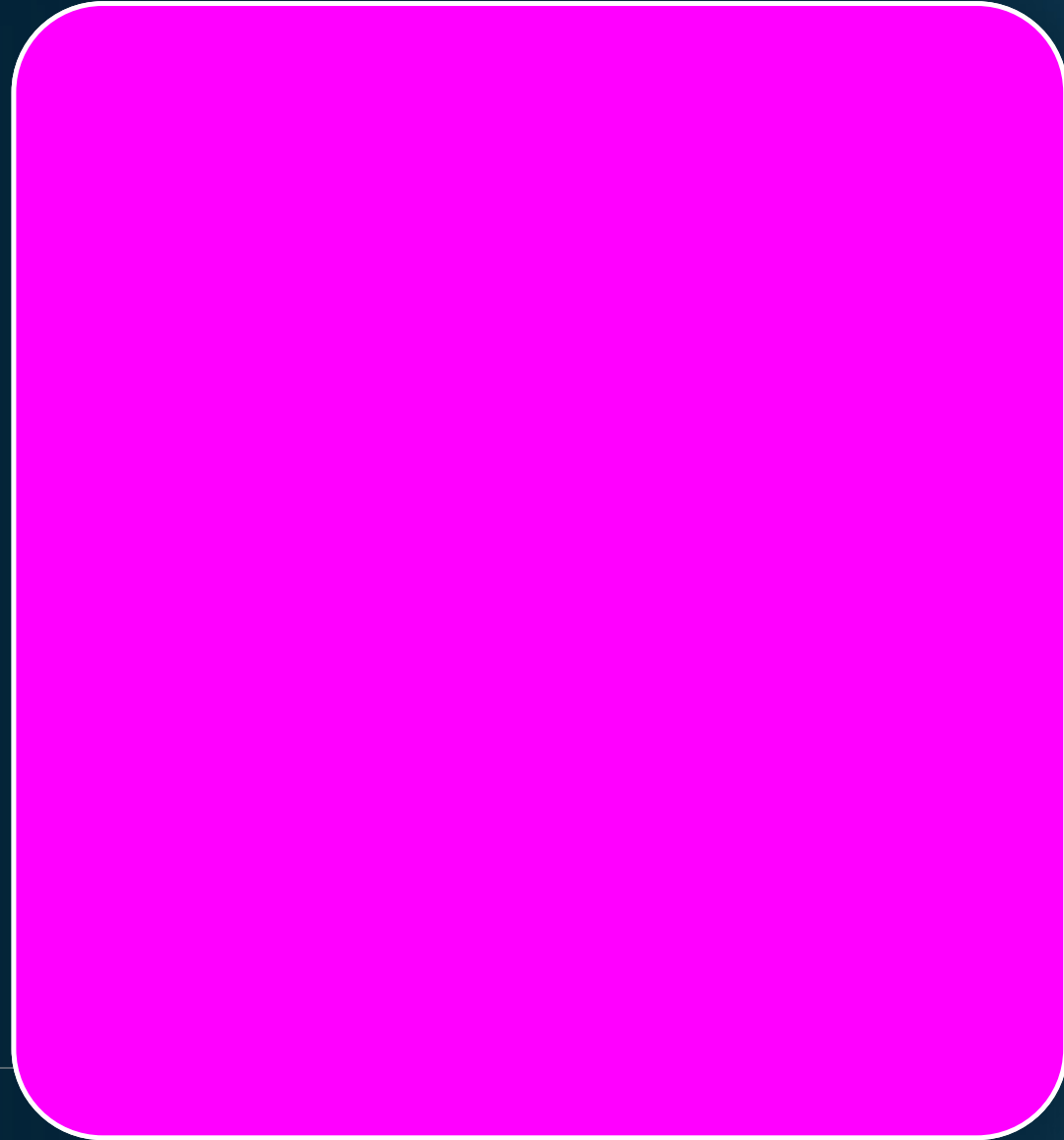
Not the model internals

Regulated sectors must explain



Privacy Beyond Compliance

Inference attacks on attributes
Training-data memorization
Re-identification by correlation
Privacy by design from day one



Explaining AI Decisions

LIME

Simpler stand-in model

SHAP

Game-theory scoring

NOT SAME

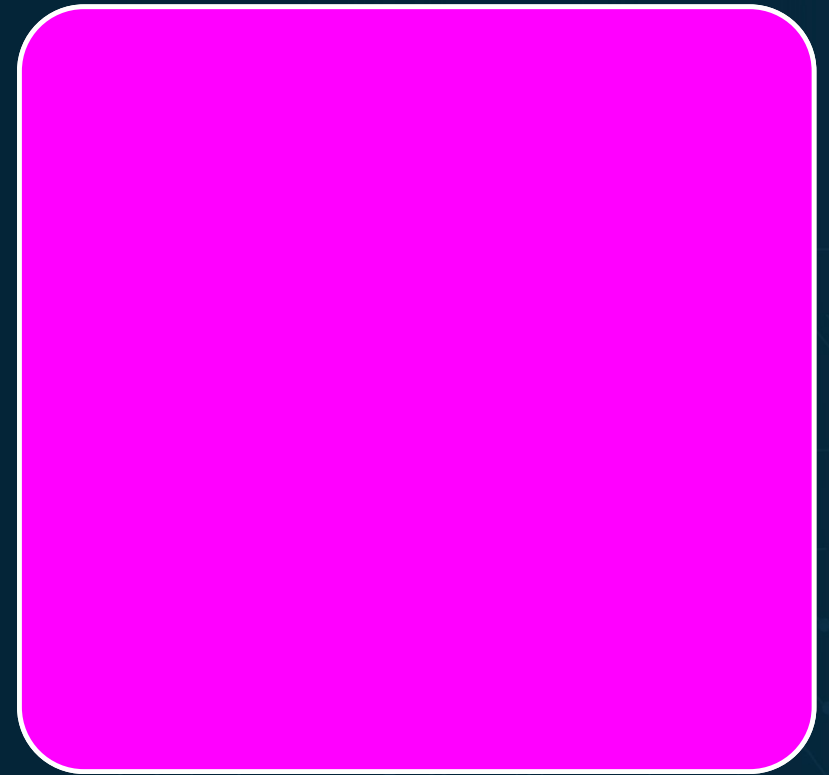
Not interpretability

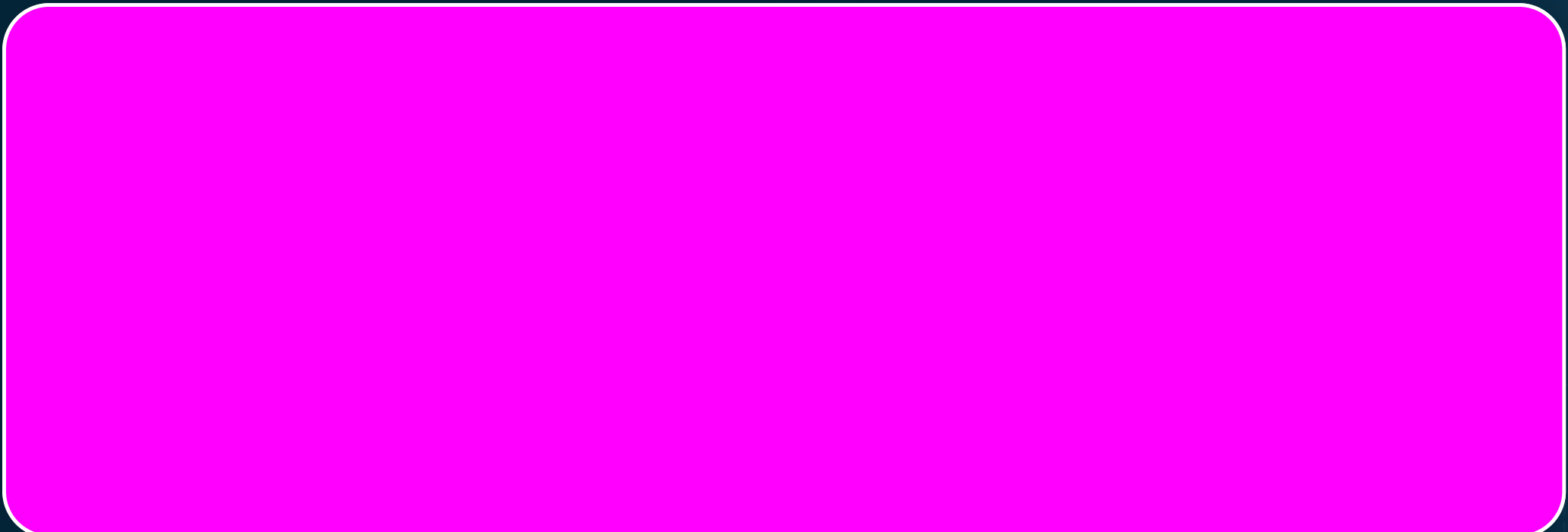
ACCOUNT

Ownership + audit trails

EXAM CUE

Know LIME & SHAP by name and function





Demo: Principles Scorecard

Five-principle audit — fairness spreads, SHAP output, scorecard

Exam Tips: Five Principles



KNOW ALL 5

Define, implement, violate



PRIVACY

Three AI-specific risks



FAIRNESS

Parity vs equal opportunity



LIME & SHAP

Names + functions suffice

AI Risk Categories

Chapter 11 · Episode 04 · Domain 4.2 — Four Risks, Four Control Sets

Bias Risk: Four Sources



TRAINING DATA

Underrepresented groups



FEEDBACK LOOP

Predictions amplify bias



LABELS

Human bias in annotation



ALGORITHMIC

Architecture favors patterns

Three Data Leakage Paths

MEMORIZE

Training-data extraction
Membership inference

INFERENCE

Prompts & RAG docs leak
Across access boundaries

INVERSION

Rebuild training data
From model outputs

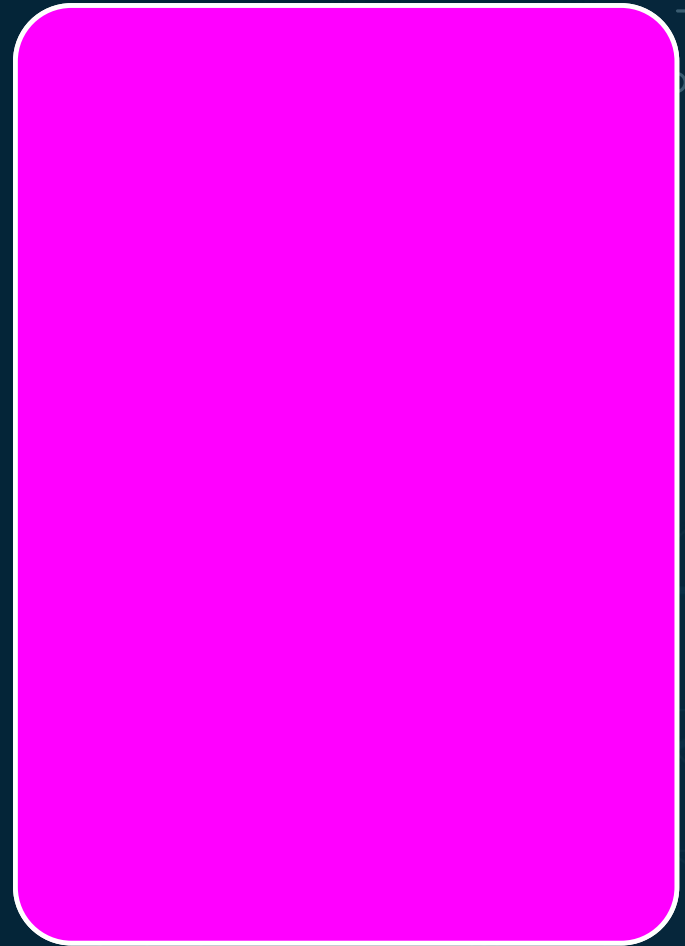
IP Risk: Three Directions

Outputs expose org IP & secrets

Model theft via extraction

Copyright liability in training

Provenance + output review



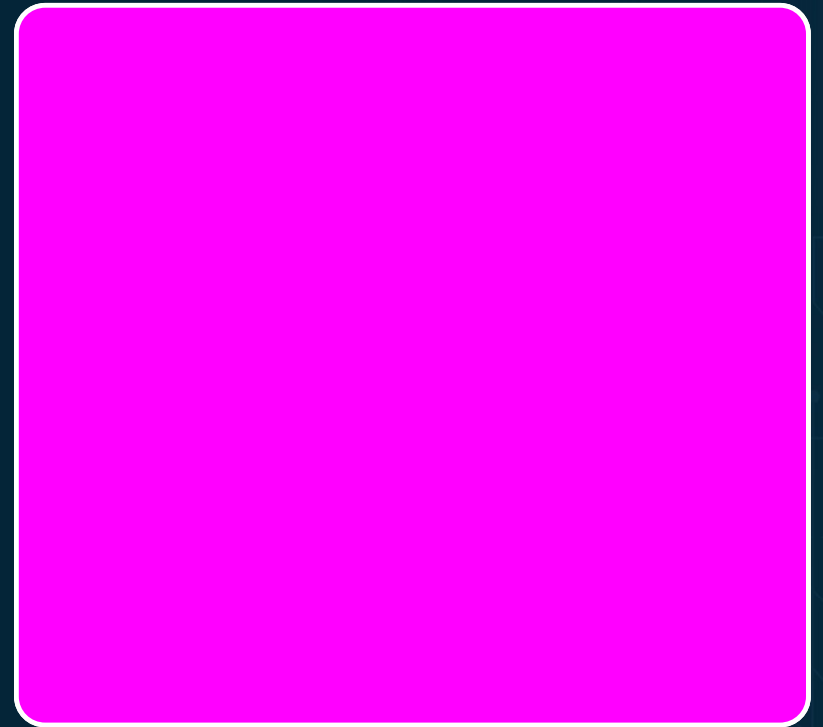
Autonomous Risk: Graduated Oversight

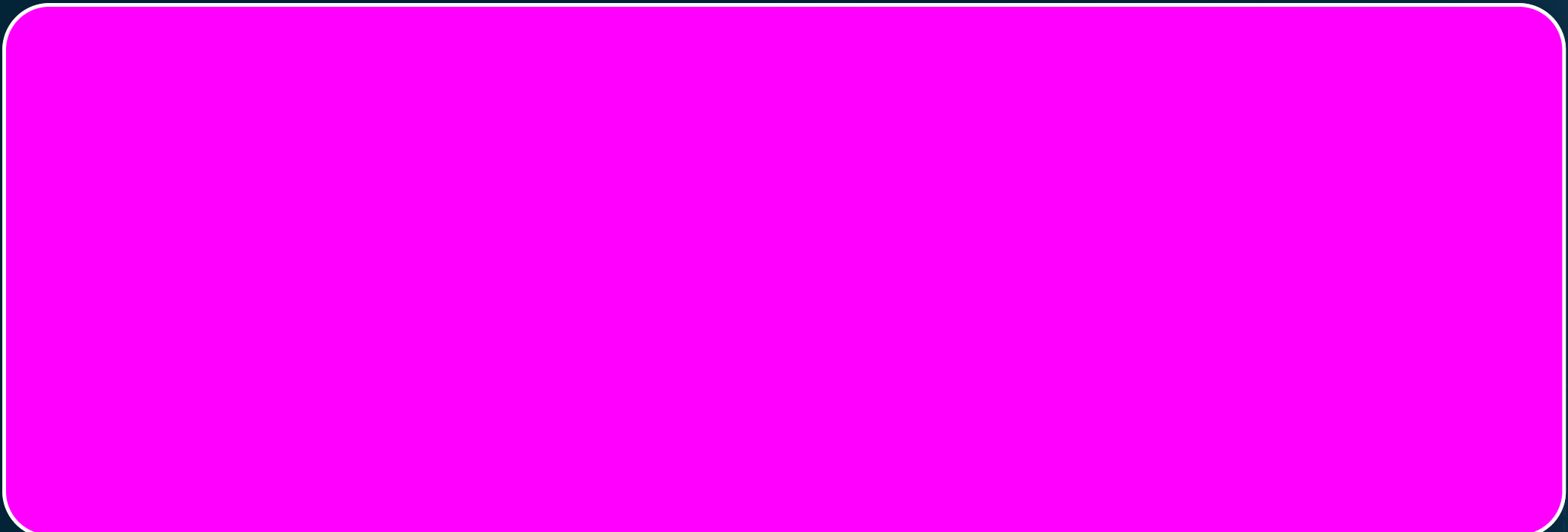
High stakes + low oversight = risk

Cascading failures pass checks

Goal misalignment at scale

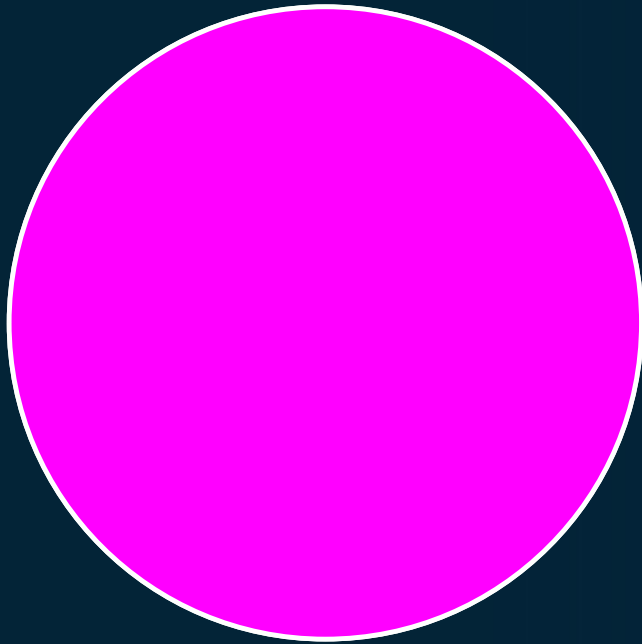
Impact drives human-in-the-loop





Demo: Risk Category Scan

Four-category simulation — bias, leakage, IP, autonomy ratings



Exam Tips

1. Four categories — sources & controls
2. Bias: data, labels, loop, algorithm
3. Leakage: memorize, infer, invert
4. IP: outputs, theft, copyright
5. Oversight proportional to stakes

Shadow AI and Unsanctioned Deployments

Chapter 11 · Episode 05 · Domain 4.2 — Governance Failure, Not Malice

Four Shadow AI Risks



EXPOSURE

Data sent to unknown clouds



CONTROL GAPS

No assessment or monitoring



COMPLIANCE

GDPR, HIPAA, CCPA violations



RELIABILITY

Unvalidated outputs drive calls

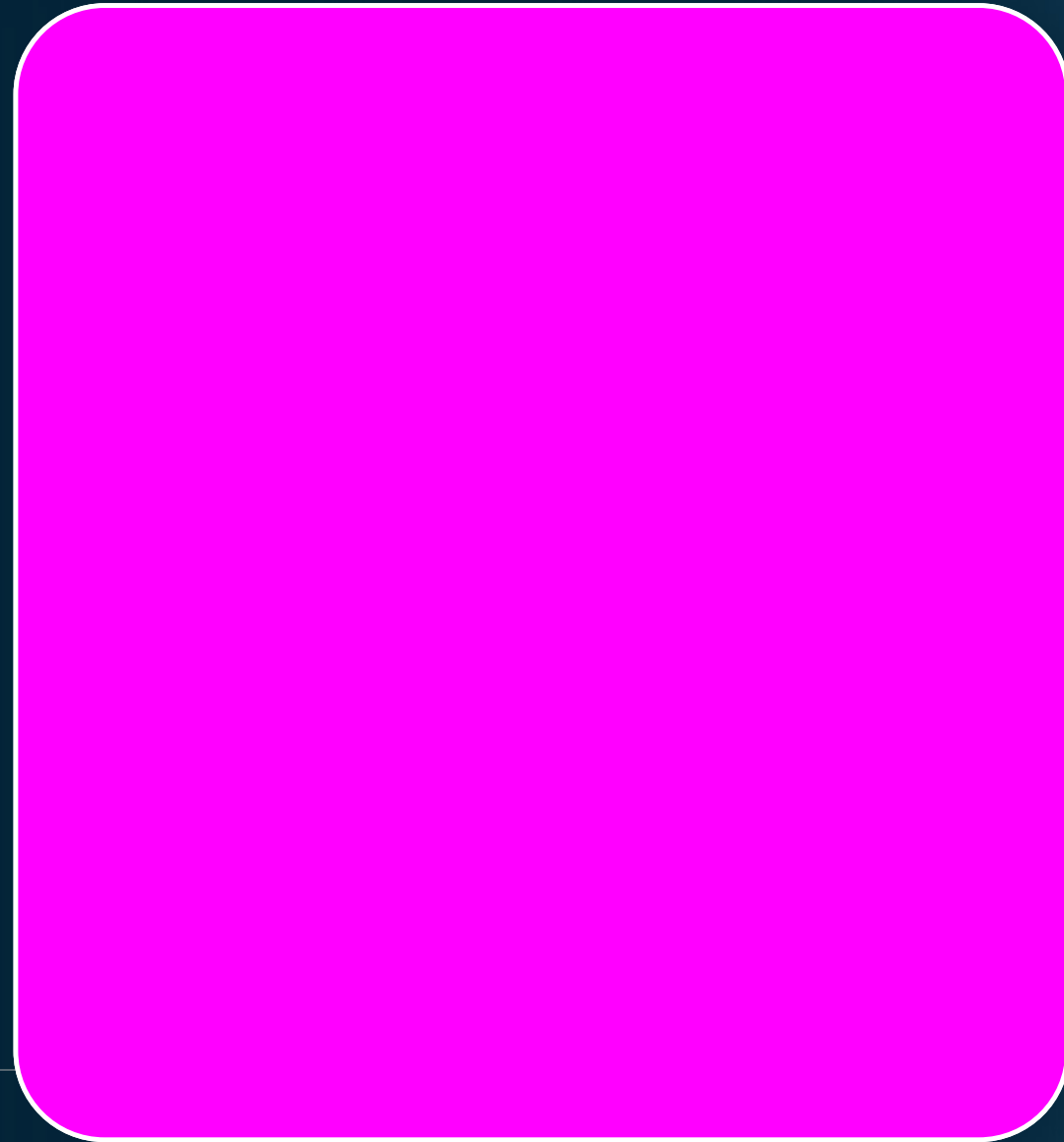
Detecting Shadow AI

Network watch on AI endpoints

DLP flags data to AI domains

Endpoint & extension monitoring

Expense trails reveal AI subs



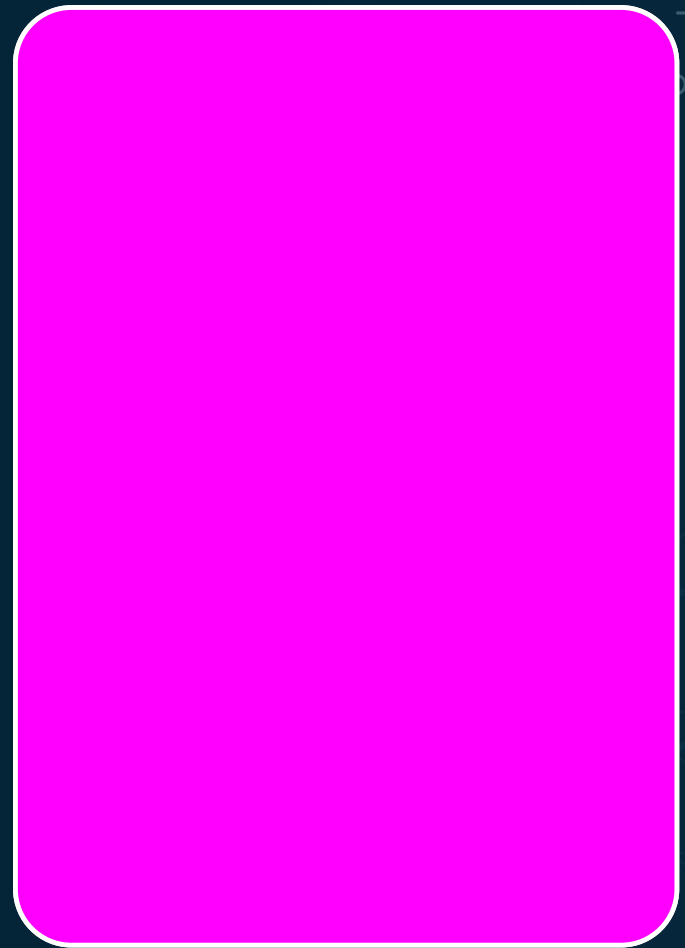
Make Compliance the Easy Path

Fast-track low-risk approvals

Curated approved-tool library

Amnesty for disclosure

Clear, accessible AI policy



Culture Closes the Gap

LITERACY

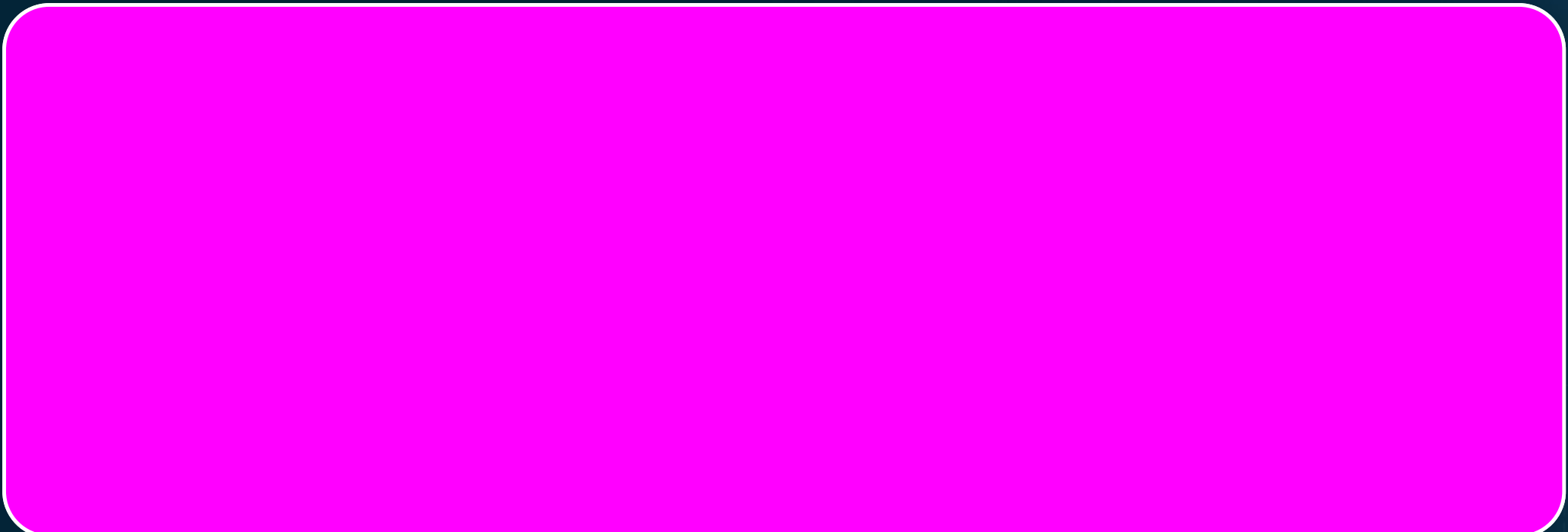
Staff understand the why
Voluntary compliance rises

SPONSORSHIP

Executives set the tone
Strategic, not checkbox

LEARNING

Transparent incident reviews
Lessons build understanding



Demo: Shadow AI Discovery

Discovery scan, risk scoring, DLP catches, governance assessment

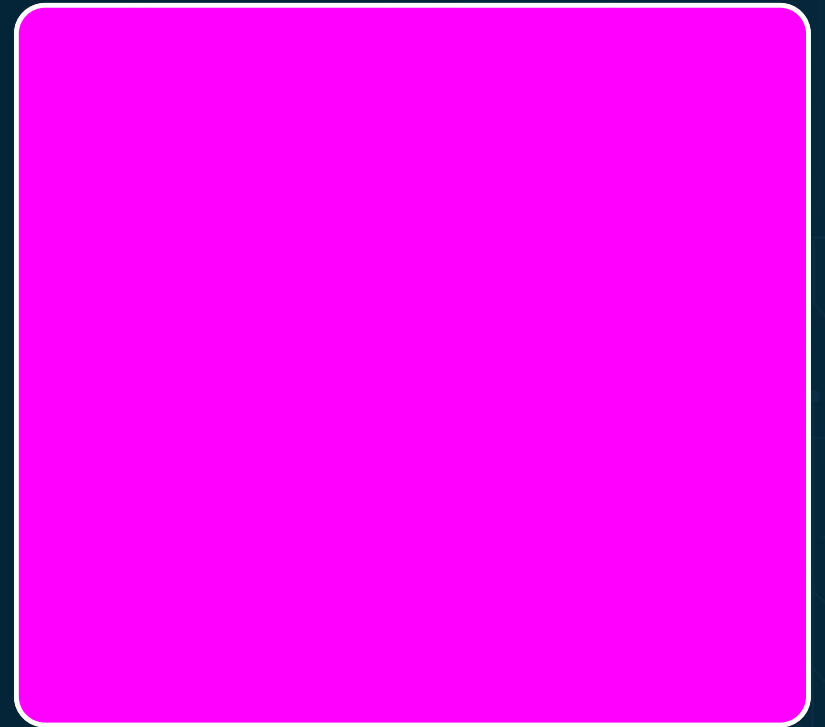
Exam Tips: Shadow AI

Driver: slow compliant paths

Four risks — exposure to reliability

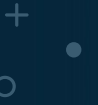
Detection: technical + financial

People-process-technology answer



EU AI Act

Chapter 11 · Episode 06 · Domain 4.3 — Four Risk Tiers, Real Penalties



Four Risk Tiers



PROHIBITED

Social scoring, live biometrics



LIMITED RISK

Disclosure: chatbots say 'AI'



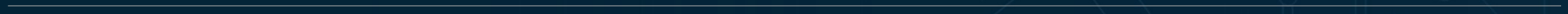
HIGH RISK

Strict pre-market rules



MINIMAL RISK

Voluntary codes of conduct



Seven High-Risk Requirements

Risk management · data governance · technical docs

Record-keeping · transparency · human oversight

Accuracy, robustness & cybersecurity — know all 7

GPAI Duties & Penalties

GPAI

Training-data summary

SYSTEMIC

Red-teaming + reporting

7% / €35M

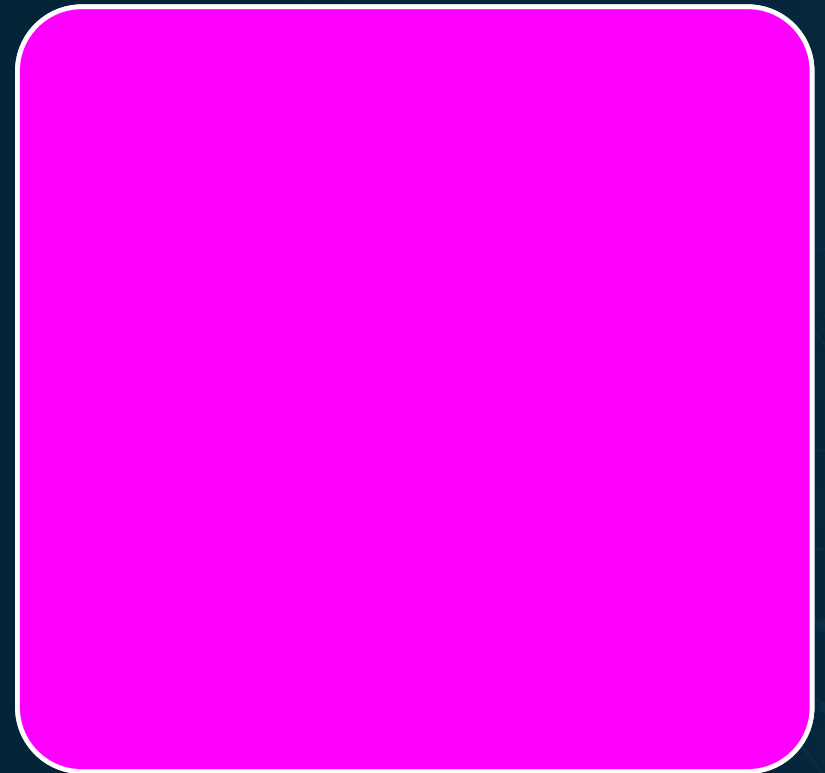
Prohibited-AI violations

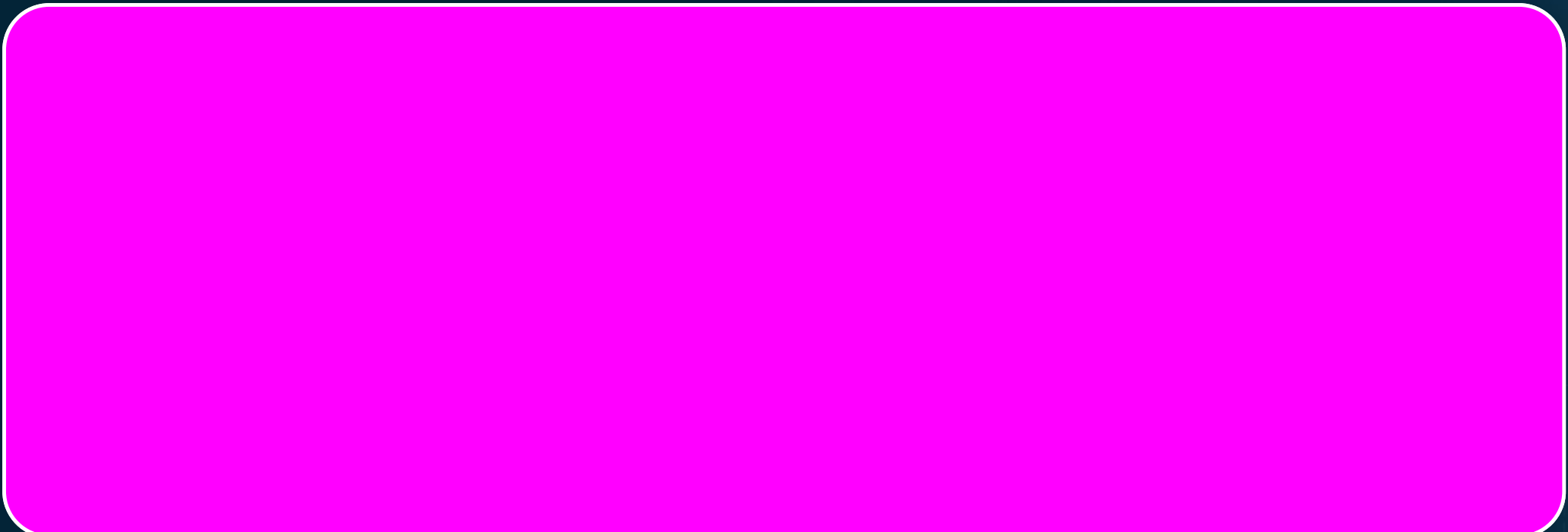
3% & 1.5%

High-risk / wrong info

ENFORCED BY

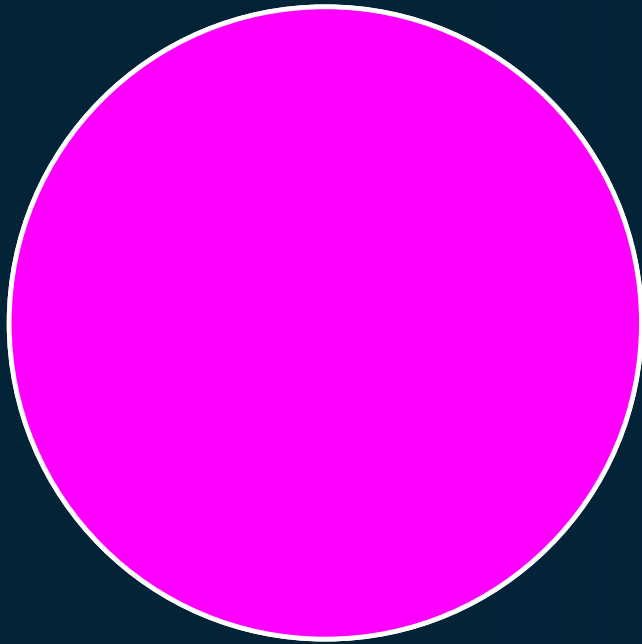
National authorities + European AI Office





Demo: AI Act Simulator

Tier classification, 7-requirement audit, penalty exposure calc



Exam Tips

1. Four tiers in order — know examples
2. Prohibited: scoring, biometrics
3. Seven high-risk requirements
4. Limited risk = disclosure duty
5. Penalties: 7 / 3 / 1.5 percent

NIST AI Risk Management Framework

Chapter 11 · Episode 07 · Domain 4.3 — Govern, Map, Measure, Manage

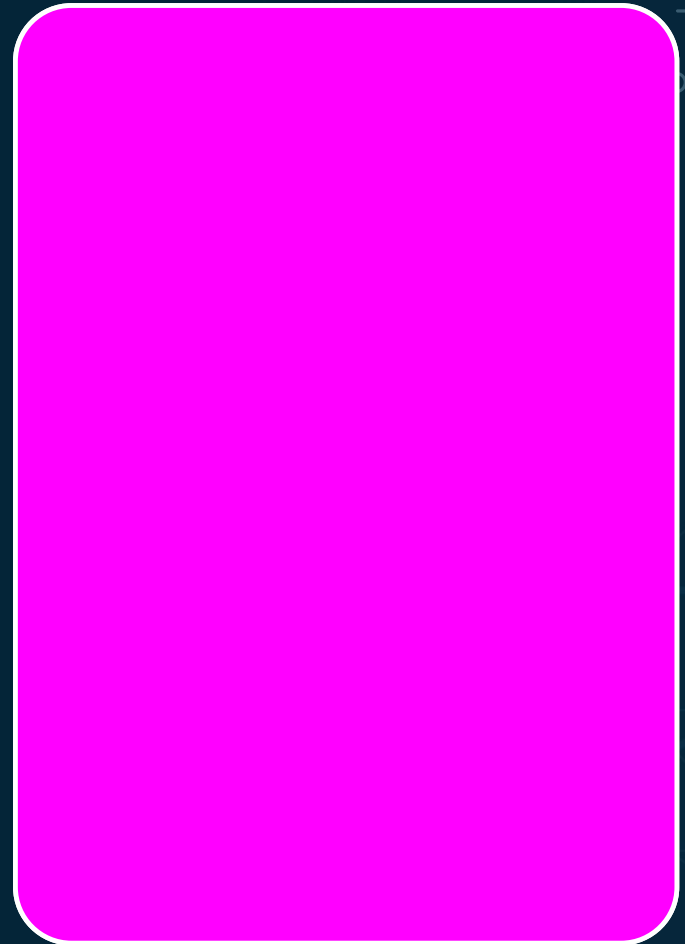
Govern: The Foundation

Policies, roles, risk tolerance

Senior leadership engagement

Cross-cutting — informs all

Absent = no authority, no RMF



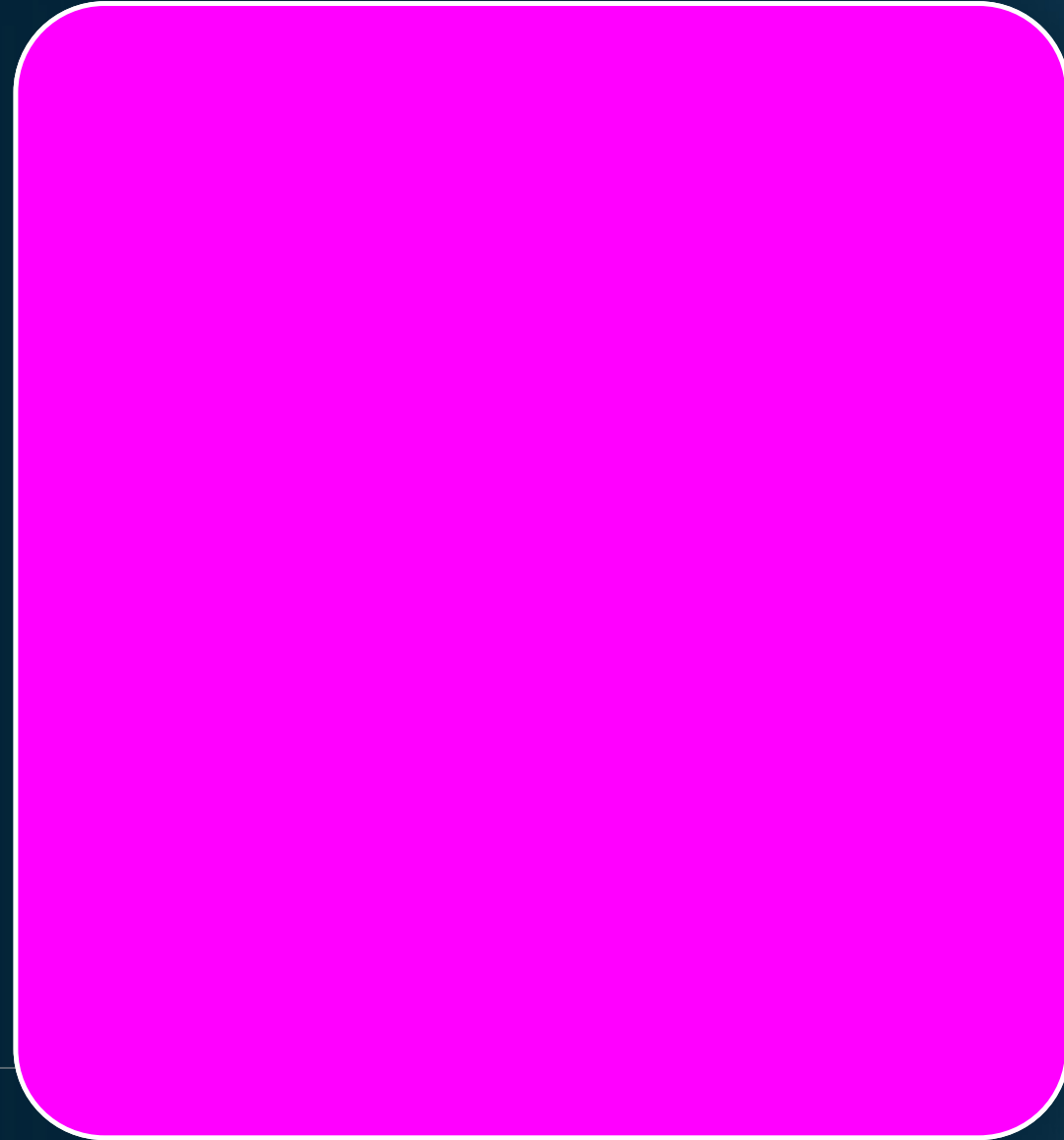
Map: Know Your Context

Categorize systems & impacts

Stakeholders, laws, ecosystem

Output: structured risk landscape

Missing = harms unknown



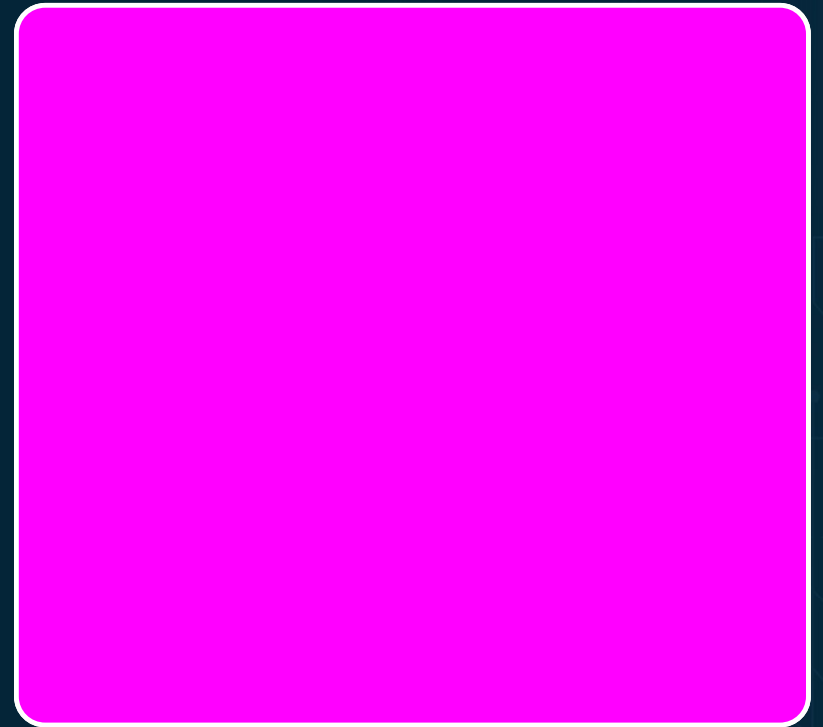
Measure: Quantify the Risks

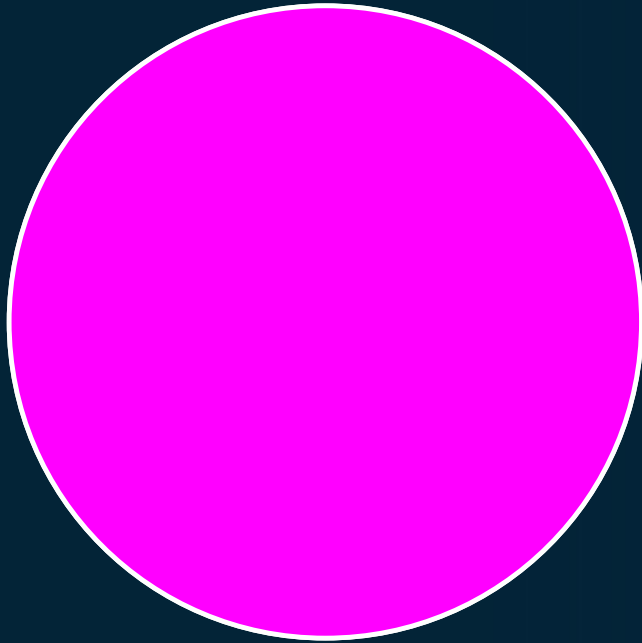
Qualitative + quantitative analysis

Fairness, safety, performance

Adversarial & red-team exercises

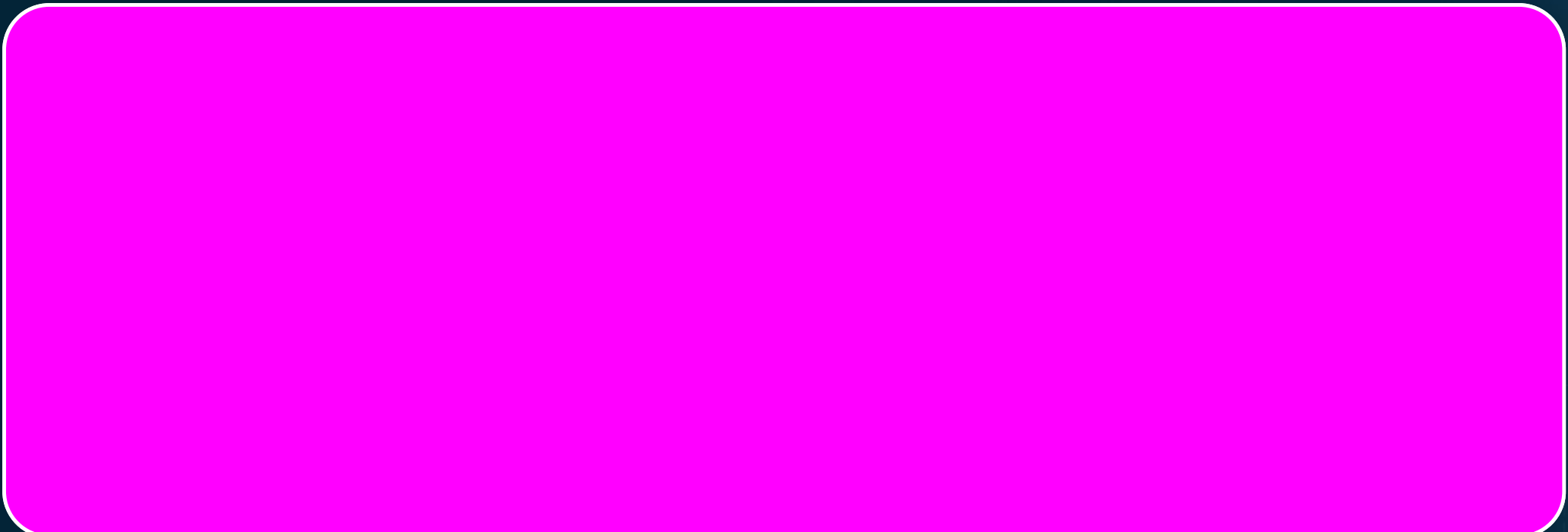
Bridges Map to Manage decisions





Manage & the Cycle

1. Implement risk responses
2. Monitor deployed systems
3. Feed lessons back into Map
4. Continuous — never one-time



Demo: RMF Gap Assessment

Four functions scored on a live deployment — lifecycle gaps flagged

Exam Tips: NIST AI RMF



GOVERN

Context, roles, tolerance



MEASURE

Quantify what you mapped



MAP

Identify risks & harms first



MANAGE

Respond, monitor, cycle back

ISO and OECD Standards

Chapter 11 · Episode 08 · Domain 4.3 — Global Frameworks, Layered

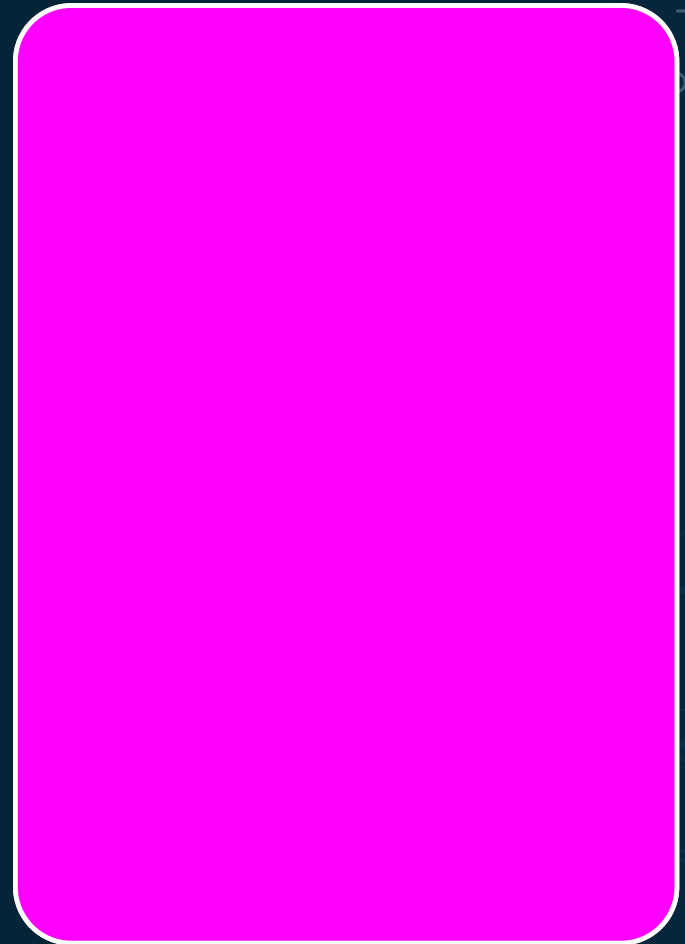
ISO/IEC 42001: AI Management

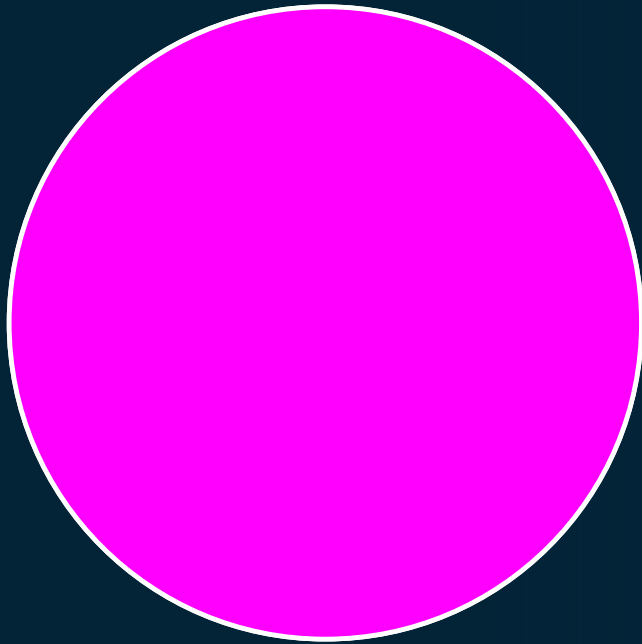
Same shape as ISO 9001 / 27001

Context, leadership, planning

Operate, evaluate, improve

Certifiable by third-party audit





OECD AI Principles

1. Inclusive growth & well-being
2. Human-centered values, fairness
3. Transparency & explainability
4. Robustness, security, safety
5. Accountability of AI actors

ISO/IEC 42001 vs NIST AI RMF

ISO/IEC 42001

International scope

Certifiable — third-party audit

Management system standard

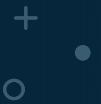
NIST AI RMF

US-origin, voluntary

No certification path

Operational risk guidance

The Layered Governance Stack



EU AI ACT

Mandatory legal floor



ISO/IEC 42001

Certifiable structure



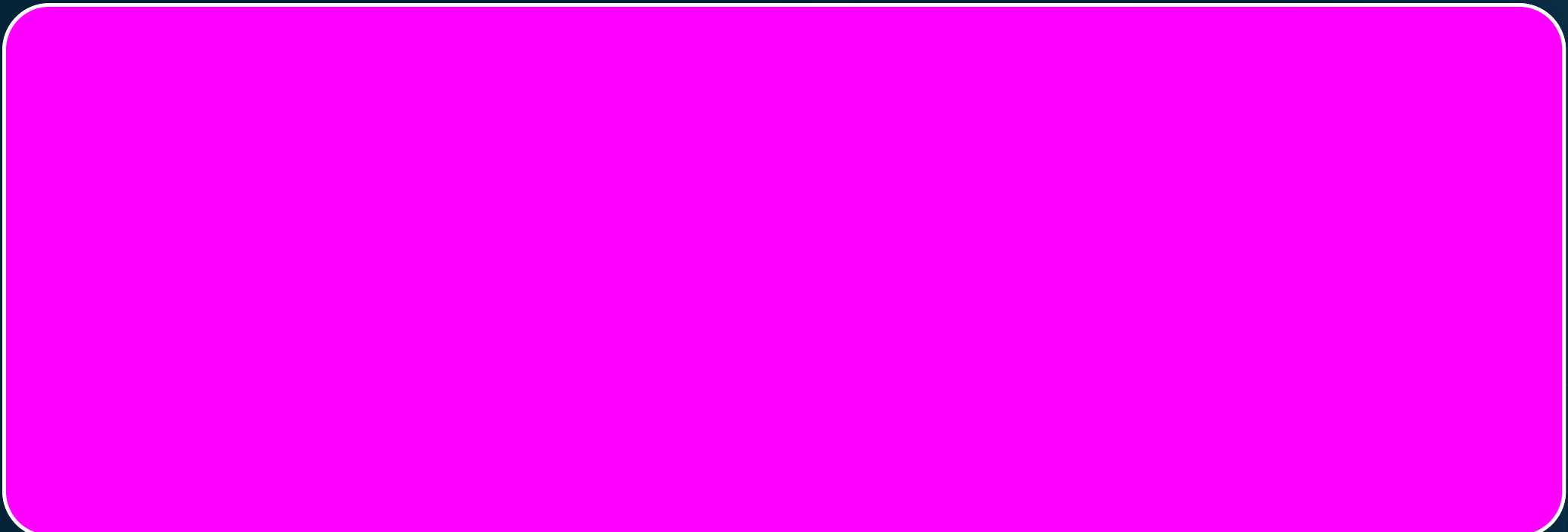
NIST AI RMF

Operational risk process



OECD

Ethical foundation



Demo: Framework Alignment

ISO/IEC 42001 clause check, OECD alignment, layered-architecture score

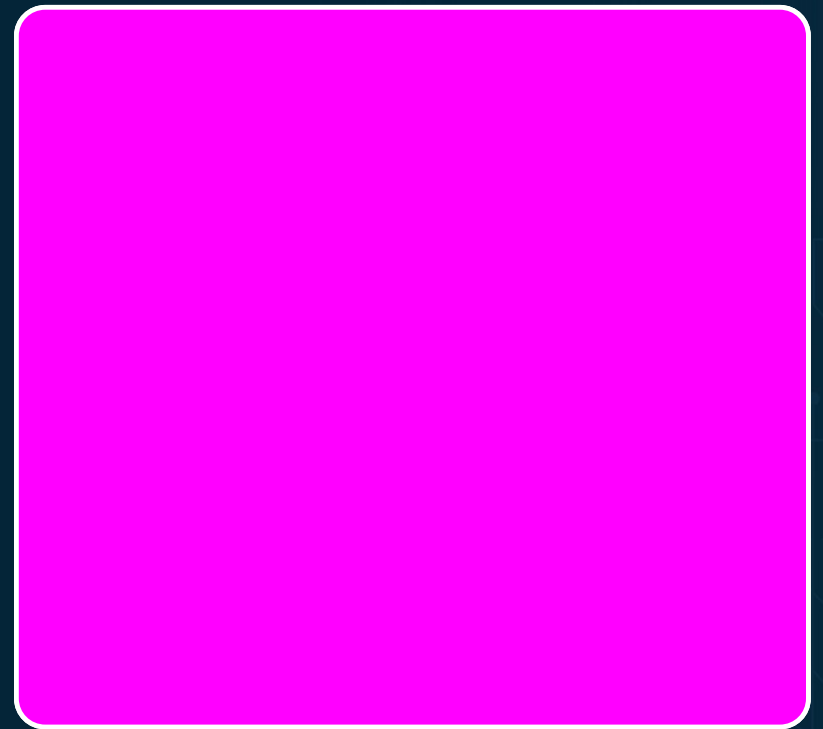
Exam Tips: ISO & OECD

ISO/IEC 42001 — certifiable, 2023

OECD 2019 — first intergovernmental

ISO international vs NIST voluntary

Each layer adds a distinct role



Corporate AI Policies and Data Governance

Chapter 11 · Episode 09 · Domain 4.3 — Policy Meets the Model Lifecycle

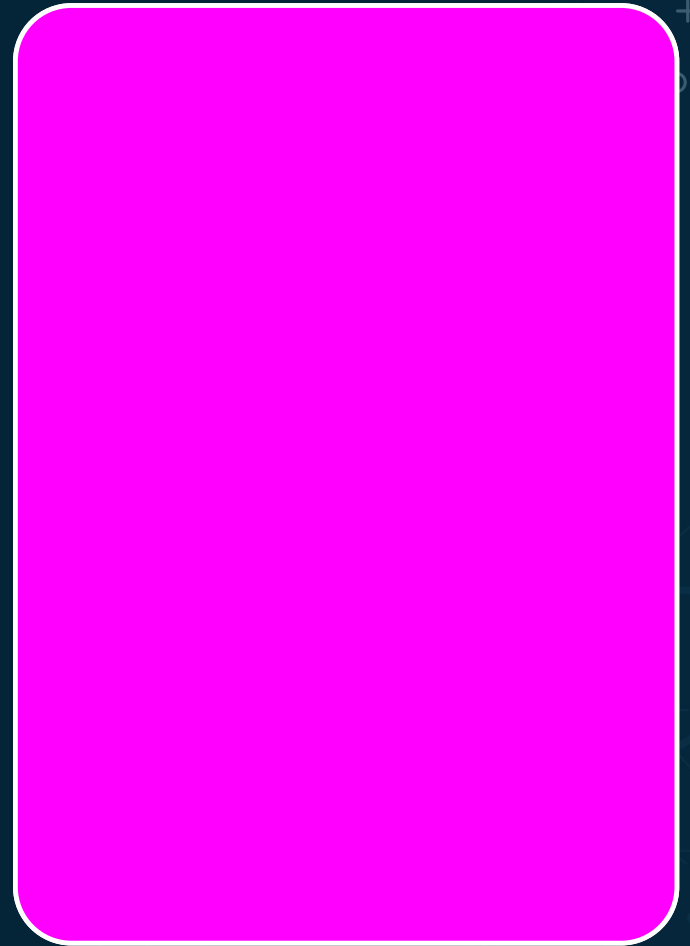
The Sanctioned Use Register

Sanctioned = assessed & approved

Register lists tools & use cases

Data types + responsible parties

No register — no audit baseline



Private vs Public Models

PRIVATE

Data stays in control boundary

Required for regulated data

PUBLIC

Data leaves the organization

Vendor terms govern retention

Four AI Data Governance Musts



PROVENANCE

Sources, licenses, consent



RETENTION

GDPR right to be forgotten



INFERENCE

Prompt rules + output filters



CROSS-BORDER

Jurisdiction transfer limits

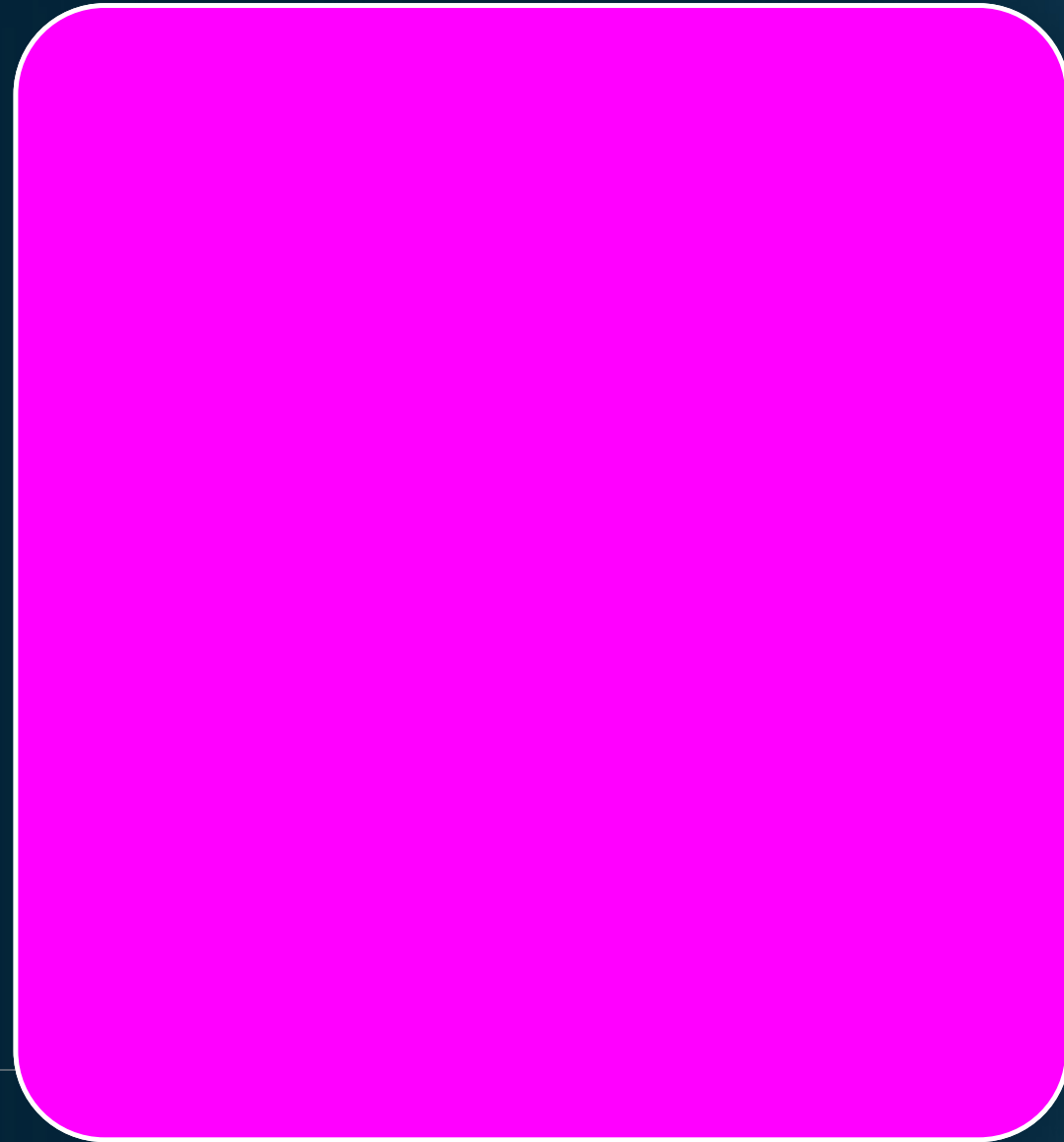
Lifecycle Stage Controls

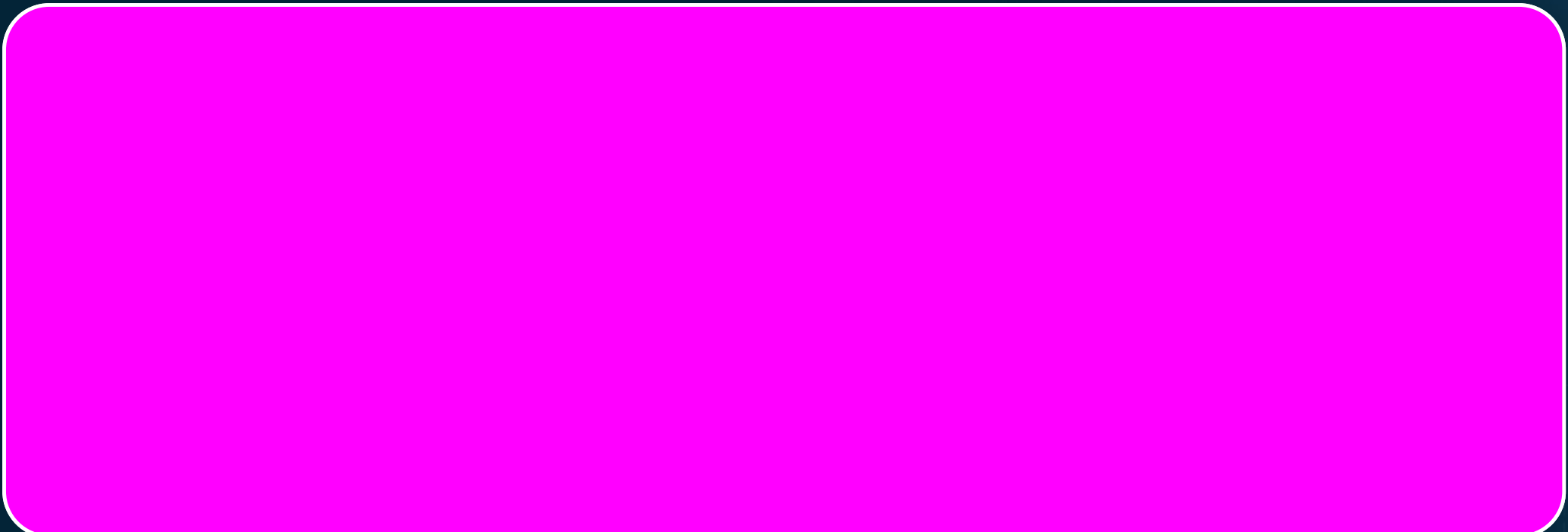
Pre-train: classify & license

Train: isolate + log access

Deploy: filter & monitor flows

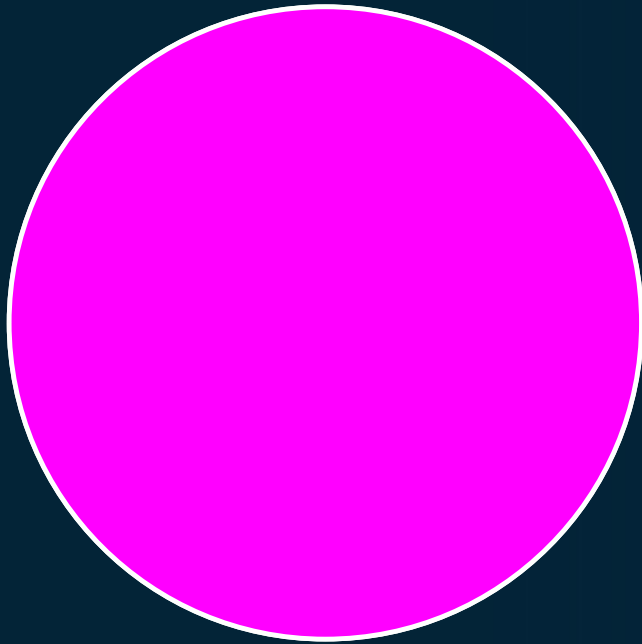
Retire: delete, document, de-list





Demo: Policy & Data Audit

Register audit, routing decisions, lifecycle checks, policy score



Exam Tips

1. Register = the audit artifact
2. Regulated data — private models
3. Four AI data governance musts
4. Lifecycle: match stage to control

Third-Party AI and Data Sovereignty

Chapter 11 · Episode 10 · Domain 4.3 — Vendors, Borders, Supply Chains

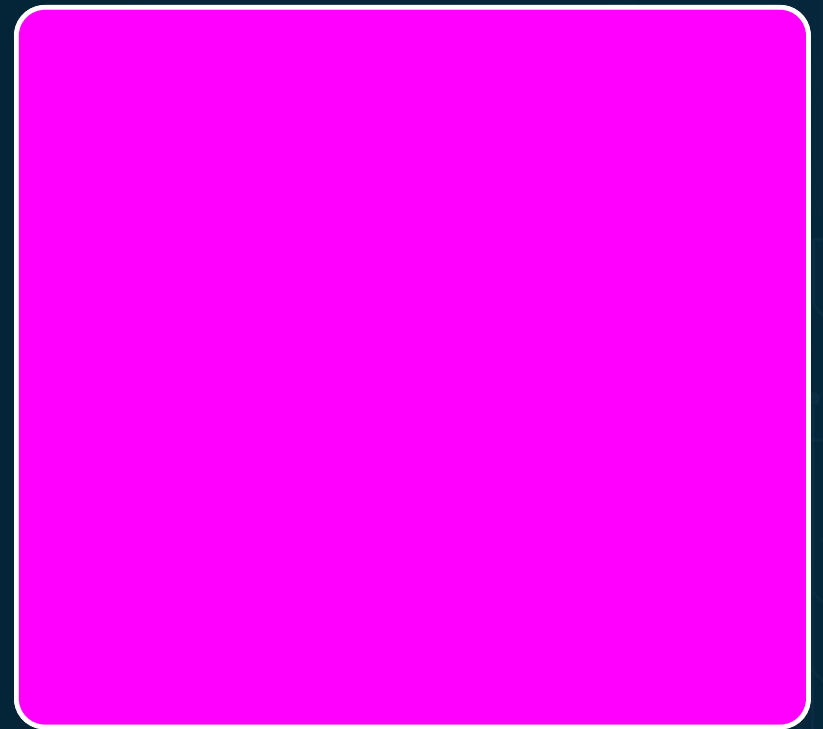
Vendor Evaluation: Beyond IT Checklists

Security posture & certifications

Data handling: where, how long

Model transparency & limits

Bias disclosure + incident plans



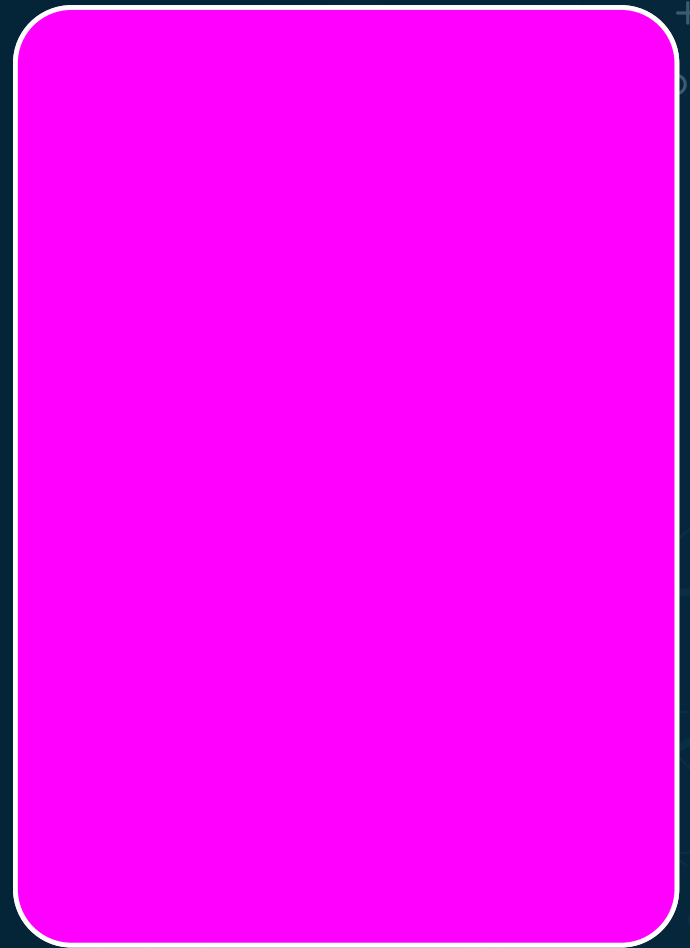
AI-Specific Contract Terms

DPA: no training on your data

SLAs for model-compromise events

Model-change notice first

Audit rights on AI governance



Data Sovereignty Basics

RESIDENCY

Where data is stored
And where it is processed

LOCALIZE

Data must stay in-country
Regulator-imposed limits

TRANSFERS

GDPR: adequacy, SCCs, BCRs
Know all three mechanisms

Four AI Supply Chain Layers



FOUNDATION

Base models power the apps



INFRA

Cloud inference platforms



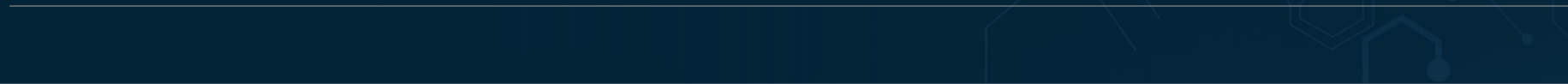
DATA

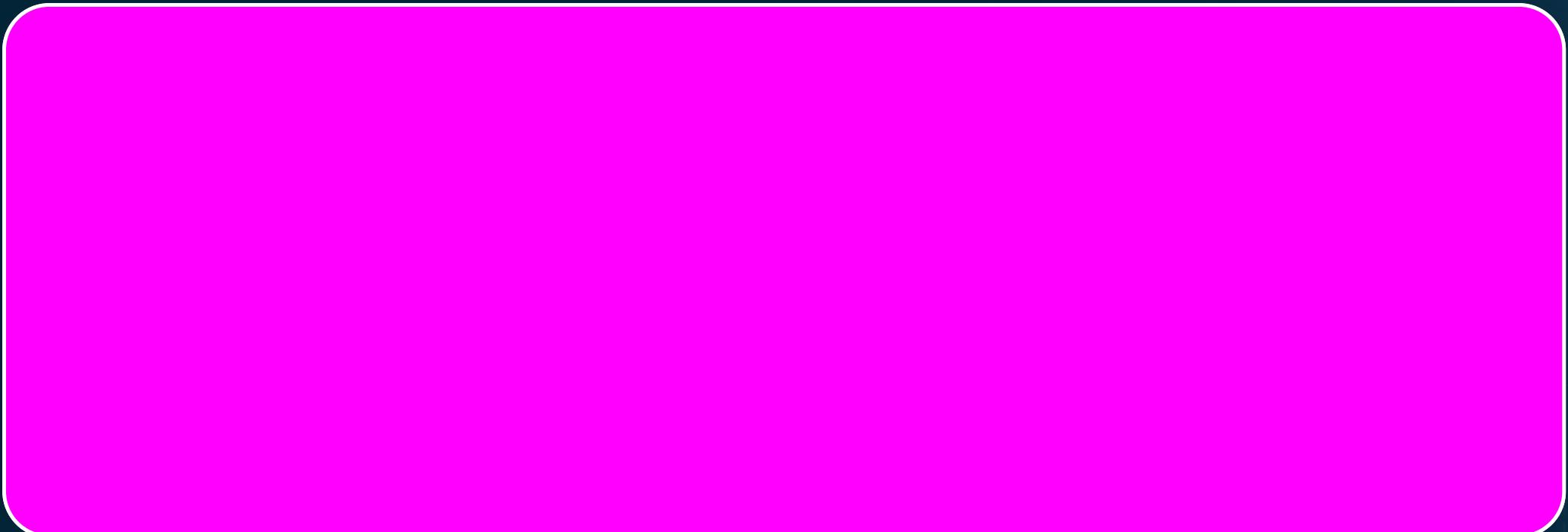
Licensed training datasets



LIBRARIES

Embedded ML parts — AI BOM





Demo: Vendor & Sovereignty

Vendor scoring, contract audit, GDPR transfer mapping, AI BOM

Exam Tips: Third-Party AI

VENDOR EVAL

Security + data + AI

CONTRACTS

DPA, SLAs, change notice

TRANSFERS

Adequacy, SCCs, BCRs

SUPPLY CHAIN

Four layers + AI BOM

